

SECAUDIT 060 - skin-boundary migration integrity

SECURITY AUDIT / PUBLIC REMEDIATION RECORD

Field	Value
Audit ID	2026-10-05-060
Date	2026-10-05
Severity	MEDIUM security-program failure / HIGH operational impact. No active exploit or confidentiality breach was found. The security remediation caused widespread availability and integrity regressions because required behavior was removed without complete bounded replacements or parity gates.
Scope	Follow-up to SECAUDIT 059: schema-v2 public skin migration, strict controllers and view models, shared asset/component contracts, package policy, deployed recovery through CMS 0.7.819D / GAME ON 0.1.24, and the CMS-owned crawler-file lifecycle repair in local candidate 0.7.820D.
Method	Repository history and diff review; pre/post migration presentation and route inventories; strict render and route regressions; full PHP regression directory; fleet skin-security ratchet; live verification of the bounded 0.7.819D recovery; and a read-only 25-site audit of robots.txt, llms.txt, /sitemap.xml, and /sitemap.php.
Status	OPEN - 0.7.819D / GAME ON 0.1.24 are deployed and bounded-live-verified; crawler lifecycle candidate 0.7.820D passes local regression gates but still requires packaging, fleet deployment, and 25-site verification. This report does not close SECAUDIT 059's remaining fleet-wide parity work.
Reporter	Codex, commissioned by Sean. Owner supplied live reproduction evidence and impact record. Independent adversarial reviewer not yet assigned.
Related	SECAUDIT 059; OPAUDIT 020; pre-migration reference v0.7.772D; controller migration beginning at c9eb3a9e.
Disclosure	Private working report until fixes are deployed and reviewed. Publication is Sean's decision.

1. Summary

SECAUDIT 059 correctly found that signed PHP skins had excessive authority. Moving data access, request handling, writes, remote calls, and reusable behavior into the CMS was the right security decision. The execution of that decision was incomplete: old authority was removed before every legitimate result it produced had a bounded replacement. The security program therefore improved isolation while damaging availability and presentation integrity.

This matters to security because a remediation is not complete when it merely removes the dangerous mechanism. It must also preserve the authorized behavior through a safer path. A project that repeatedly restores missing behavior under emergency pressure is more likely to reintroduce authority, bypass gates, or normalize exceptions. The recovery itself therefore requires a security review, not only visual QA.

The deployed 0.7.819D / GAME ON 0.1.24 recovery retains the intended boundary. Validation, routing, data loading, repair decisions, and shared interactions remain in core or audited shared assets. GAME ON receives bounded display data and contains presentation-only template logic. TILEZ is not changed. The fleet security ratchet passes.

2. Findings

A. The security migration had no behavior-preservation gate (MEDIUM) - OPEN

Evidence: the constrained-controller migration began after v0.7.772D. Security and architecture tests passed while live skins subsequently lacked saved settings, backgrounds, navigation, controls, full feeds, search, image associations, routes, Blogrolls, static-page presentation, and footers. A read-only route audit later found 45 declared-route falthroughs across 12 skins. A presentation diagnostic found 646 candidate pre-migration CSS hooks still referenced by current styles but no longer emitted.

Failure mode: authorized behavior silently disappears while the security gate stays green. The resulting emergency repairs create pressure to put logic back into templates, accept one-off exceptions, or weaken the scanner. Availability and content integrity are reduced, and confidence in the boundary becomes dependent on live users finding omissions.

Required fix: every security-boundary migration must have a two-sided gate: forbidden authority is absent, and required behavior is present through bounded contracts. The parity half must cover routes, settings, markup/components, registered assets, interaction behavior, responsive behavior, and saved non-default values.

B. Generic replacement layouts obscured capability-to-presentation dependencies (MEDIUM) - OPEN

Evidence: repository history contains mechanical replacement scripts for grid, public, and SMACKTALK families. Representative skins that previously had many route-specific templates and partials were reduced to a generic strict layout without a complete ledger of what each old path legitimately supplied.

Failure mode: security-sensitive removal and ordinary presentation redesign become mixed in one large mechanical change. Review can prove that SQL or request access vanished while missing the data attributes, component anchors, or bounded fields needed by a central engine.

Required fix: migration plans must map each old capability to one of three outcomes: forbidden and removed; legitimate and replaced by a named bounded contract; intentionally retired with owner approval. Bulk replacement is prohibited for independently packaged skins.

C. The recovery path was capable of drifting back toward template logic (LOW, caught) - CLOSED LOCALLY

Evidence: during the GAME ON recovery, a draft placed display-field validation and local decision variables in the skin template. The fleet security ratchet rejected the candidate before release. Validation was moved into `core/public-runtime.php`; the template now only escapes and presents the prepared values. The ratchet then passed.

Disposition: this did not ship. It is recorded because it demonstrates both the pressure created by incomplete contracts and the value of the fail-closed ratchet. The gate must remain mandatory in skin packaging, CMS release, and installation paths.

D. Release evidence did not distinguish security closure from visual parity (MEDIUM process) - OPEN

Evidence: multiple releases after the boundary conversion were described as restorations, yet further omissions were found only on live sites. Source assertions, asset registration, and generic rendering success were repeatedly treated as sufficient evidence of recovery.

Failure mode: a security fix can be marked complete while the product remains degraded, then subsequent fixes are made without the same deliberate threat review as the original migration. Release volume also makes it difficult to identify which package introduced or closed a specific boundary defect.

Required fix: release notes and gates must state separately: boundary controls verified; source behavior verified; packaged artifact verified; installed target verified; live user interaction verified. Only the last can close parity for that target.

E. Generated crawler files were excluded from install/update integrity (MEDIUM) - OPEN PENDING DEPLOYMENT

Evidence: a read-only audit of the hub and 24 connected sites found `/sitemap.xml` returning 404 on all 25 sites while the internal `/sitemap.php` endpoint returned XML on all

25. Ten sites had no `llms.txt`; the other 15 embedded CMS versions between 0.7.401 and 0.7.718D instead of the installed 0.7.819D. Six sites had no `robots.txt`, and four additional robots files advertised stale or malformed sitemap locations. The generator was reachable only from manual settings, maintenance, and policy

actions. The canonical .htaccess template lacked the route the generator advertised, and the fleet updater did not reconcile the generated files.

Failure mode: a correctly signed and successfully installed CMS update can leave public search and agent policy files absent or stale indefinitely. That is an integrity failure at the update boundary: the running software version and its public machine-readable claims no longer describe the same state. It also creates pressure for per-site manual repair and hides one central defect behind apparent fleet drift.

Required fix: one core-owned reconciliation function must run after version stamping in fresh install, ordinary update, uploaded-package update, and fleet update paths. It must install the canonical /sitemap.xml route, regenerate robots.txt, llms.txt, and security.txt from current settings, and invalidate the sitemap cache. Generated llms.txt must use the newly stamped database version during the same request rather than the stale in-memory constant. Deployment closes only after all 25 sites pass the same read-only audit.

3. Current candidate boundary review

Change	Authority owner	Data passed to skin	Security disposition
Clean route aliases and legacy redirects	CMS core	Final escaped URLs in navigation	Central validation and canonicalization; no request parsing added to skins.
SMACKTALK diary/image-archive split	CMS controller	Named response kind and bounded entries	Query and route authority remain central.
GRAMOFSMACK duplicate Archive suppression	CMS view-model/router	Navigation item omitted	No skin-side request or settings access.
GAME ON secondary-page background/count	CMS public runtime/repository	Bounded count and puzzle item array	Same approved view contract as landing; no PDO reaches the skin.
GAME ON page hero and Blogroll	CMS runtime/controller	Validated image presentation fields and grouped public links	Template performs presentation only; unsafe URL/content paths remain escaped or trusted centrally.
Standard footer	CMS component renderer	SnapTrustedHtml component token	Skin emits an already bounded component; no settings access.
Existing SMACKPRESS page repair	Authenticated API/tool	Existing page and media identifiers	Reuses imported media; refuses ambiguous changes; does not broaden public skin authority.
Crawler-file lifecycle	CMS install/updater core	Current settings and stamped installed version	No skin authority; one core generator reconciles machine-readable files and public sitemap routing across every update entrance.

4. Tests and evidence

- Focused public-route, GAME ON, SMACKTALK-family, TILEZ-completion, and GRAM menu tests pass.
- Fleet skin-security ratchet passes after the template-side draft was corrected.
- Full PHP regression directory at the 0.7.820D source checkpoint: **164 passed, 0 failed**.
- `git diff --check` passes.
- CMS source is exactly 0.7.820D; deployed GAME ON is exactly 0.1.24; TILEZ remains

0.2.59. No skin files changed in 0.7.820D.

- CMS 0.7.819D and GAME ON 0.1.24 have packaged/deployed/live evidence for their bounded recovery. No package or live claim is made yet for 0.7.820D; that gate remains open.

5. Six-chokepoint review

1. **Untrusted image ingress:** unchanged by this candidate. Page-image and imported-image references reuse existing sanitized/owned media paths. No decoder or upload authority is added to a skin.
2. **Config / manifest ingestion:** GAME ON stays schema-v2/security-policy 2. Its single declared template remains subject to the mandatory skin gate. No executable asset is added.
3. **JavaScript / IPC:** interaction stays in registered CMS assets. No skin JavaScript or desktop IPC is introduced.
4. **Update / restore channel:** release ordering remains an open operational control. The candidate must be packaged, signed, installed, and verified sequentially; no later version may be created first.
5. **Credentials / tokens:** no credential path changes and no credential material enters a view model or skin package.
6. **Upload / SSRF:** no new remote fetch or upload surface. SMACKPRESS repair uses the existing authenticated API and refuses ambiguous media-count changes.

6. Closure requirements

- [x] Current recovery diff passes the fleet security ratchet.
- [x] Full local regression directory passes (164/164).
- [x] Candidate version is sequential: CMS 0.7.820D; GAME ON 0.1.24 and TILEZ 0.2.59 unchanged.
- [x] CMS 0.7.819D and GAME ON 0.1.24 installed and bounded-live-verified.
- [] Independent adversarial source review completed and disagreements recorded.
- [] Signed CMS 0.7.820D artifact inspected and deployed to hub plus all 24 connected sites.
- [] Post-deployment audit proves current robots.txt and llms.txt plus working /sitemap.xml on all 25 sites.
- [] Remaining 059 fleet-parity candidates classified; no whole-fleet closure claimed from this bounded repair.
- [] OPAUDIT 020 updated with final deployment evidence and owner-approved close state.

7. Plain admission

The project enforced the new security boundary before it had fully designed or tested the replacement contracts. That made the code less powerful in skins but the product less reliable for users. Security work that breaks authorized behavior and then requires weeks of emergency restoration is not a successful rollout. The boundary should remain; the migration and release process must be corrected. We also represented CMS-owned crawler files as maintained before verifying that assertion. The fleet proved otherwise: the generator was disconnected from installation and updates, exactly the kind of missing lifecycle connection this recovery is supposed to prevent.